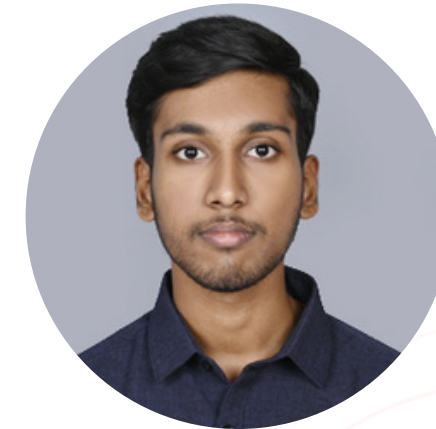


Team Name: ZENITH

Team Members:



Bhavesh B N



Harnishraj K

Institute Name: PSG Institute of Technology and Applied Research

Problem Statement: Software Supply Chain Risk Scorer (SBOM Analyzer)

Approach: (Option **A**) AI-Powered Supply Chain Intelligence (Advanced)

Git Repository: https://github.com/Bhavesh-Reddy/Zenith_SG.git



Problem Statement

Challenges in Software Supply Chain Security

- Modern applications rely on hundreds of direct and transitive open-source dependencies.
- Vulnerabilities in nested (transitive) libraries often remain unnoticed.
- License incompatibilities can introduce legal and compliance risks.
- Existing tools generate numerous alerts without prioritizing the most critical issues.
- Security teams struggle to identify which vulnerabilities require immediate remediation.

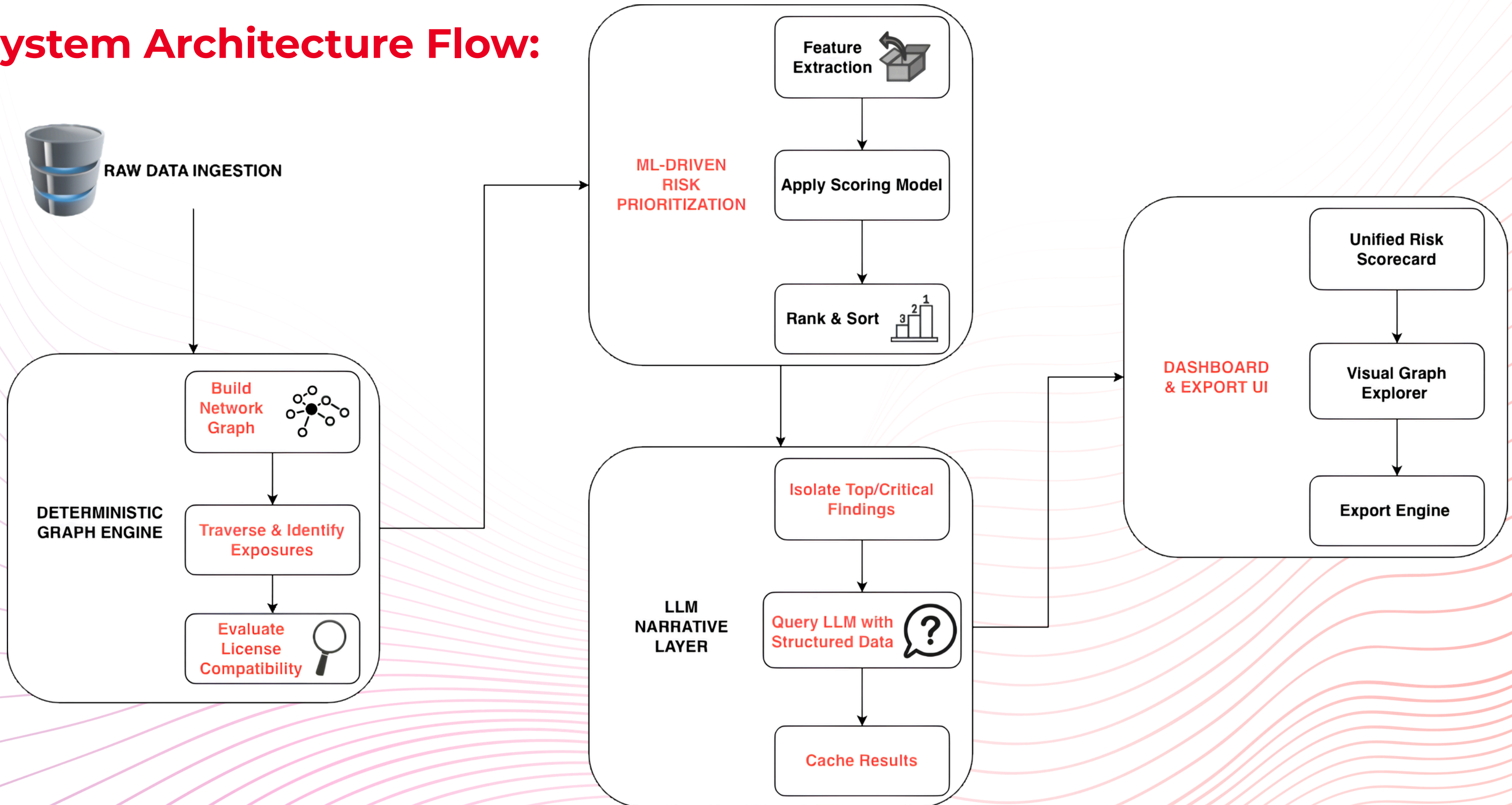


Proposed Solution

AI-Powered SBOM Risk Scorer

- Build a dependency graph to trace direct and transitive library relationships.
- Detect known vulnerabilities (CVEs) and identify license conflicts.
- Apply Machine Learning to assign a risk score based on multiple security factors.
- Generate evidence-backed reports showing the complete dependency path to each issue.
- Use an LLM to provide clear remediation recommendations for faster decision-making.

System Architecture Flow:



Model Evaluation

Both scorers, evaluated on the
identical 20 % stratified holdout
(seed 42)

Scorer	Precision	Recall	F1	FPR
Baseline formula	73.4 %	100 %	0.847	32.1 %
GBDT (HistGBC)	83.3 %	74.5 %	0.786	13.2 %

Self-evaluation

vs.

Official targets
(deterministic core only)

Target	Required	Result
Vulnerability Detection	> 85 %	98.3 % (173/176)
Transitive Resolution	100 %	100 % (150/150)
License Conflict Detection	> 90 %	100 % (16/16)
False Positive Rate	< 20 %	39.1 % (104/266)
Risk Score Accuracy (± 10)	> 90 %	68.0 % (340/500)